Asset Inventory and Threat/Vulnerability Identification

Asset Name	Asset Description	Associated Threats	Potential Vulnerabilities	Mitigation Notes
Employees	1,200 Employees.	Social engineering attacks, phishing, insider threats.	Poor training, disgruntled employees.	Implement extensive security awareness training, provide employees with PTO, vacation time, etc.
E-Commerce Website & Mobile Application	Very robust service with integrated PayPal & Afterpay gateways.	DDOS, SQLi, brute force.	Insecure gateways, data storage, or weak passwords.	Implement robust IPS, Firewalls, and password policies.
Cloud Infrastructure	Cloud POS, Customer relationships managed in Salesforce, SAP for enterprise planning for inventory, finances and HR. AWS used for hosting and third-party services.	Misconfiguration, data exposure, third-party compromise, privilege escalation.	Weak storage buckets, poor IAM roles.	Implement strong SASE infrastructure, manage IAM roles, encrypt data in all states.
Physical Stores	85 stores nationwide.	Physical break-in, theft.	Weak CCTV system, locks, or alarm system.	Implement outdoor lighting, robust CCTV and lock/alarm system.
Customer Data	Handling PII, tokenized payment details, purchase history, and behavior/rewards analytics.	Data breach.	Weak data storage, no data retention policy, incorrectly implemented RBAC.	Continuously audit the RBAC system, data storage systems, and implement date retention policy.
BYOD Policy	Employees are allowed to bring their own device to access internal systems.	Employee device compromise, malware, data leakage.	Weak EDR/XDR and data separation.	Implement strong EDR/XDR tooling and secure all endpoints, separate propriety and personal data on devices.
VPN and Remote Access to Internal Systems	Employees can remotely access internal systems via VPN.	Credential snuffing, brute force.	Lack of MFA, weak passwords, and protocols.	Use strong network protocols, MFA, and passwords.
Internal Communication Systems	Employees communicate on Microsoft Teams and Slack.	Phishing links, data leakage.	Lack of monitoring, no DLP system.	Implement strong DLP systems, as well as continuous monitoring.

Risk Criteria

The below explains what each item in the Risk Assessment means.

Criteria	Description
Risk Description	Detailed explanation of the scenario, what could go wrong, and why it matters.
Assets at Risk	The information, system, or service impacted (e.g. customer data, VDI environment).
Threat	Who or what could cause the risk (e.g., insider, cybercriminal, accident, malware). The action or event (e.g., data exfiltration, privilege misuse, physical theft).
Vulnerability	Weakness – the gap or condition that enables the threat (e.g., extended idle session, clipboard sharing).
Existing Controls	Current safeguards in place (e.g., MFA, logging, endpoint DLP).
Inherent Risk Rating	Risk level before any mitigations are applied.
Residual Risk Rating	Risk level after current controls are considered.
Likelihood	The probability of occurrence (e.g., Rare, Possible, Likely).
Consequence	Severity – level of damage if realised (e.g., Minor, Moderate, Major, Extreme).
Rating	The outcome of the risk likelihood and consequence evaluation.
Mitigations	Treatment Plan – actions to reduce, transfer, avoid, or accept the risk.
Risk Owner	Person or role accountable for managing the risk (e.g., the person who uses the software)

Risk Assessment

Complete this assessment for at least 3 risks.

Risk Details			
Risk ID	R1	**Date Identified**	3/31/2026

Risk Title	Phishing Attack Resulting In Credential Compromise	**Review Date**	3/31/2026
Risk Identification			
Risk Description	Employees may receive phishing emails leading to credential compromise. Compromised credentials would lead to access of sensitive systems and data.		
Assets at Risk	Employees, Customer Data, Customer Relationships, Internal Servers.		
Threat	Attackers using social engineering or phishing methods.		
Vulnerability	Lack of robust and comprehensive security training.		
Existing Controls	Basic security awareness training.		
Inherent Risk Analysis			
Likelihood	**Consequence**	**Inherent Risk Rating**	
4	4	High	
Residual Risk Analysis			
Likelihood	**Consequence**	**Residual Risk Rating**	
2	4	Medium	
Risk Treatment			
Mitigations	Enforce MFA and Zero Trust systems, increase security awareness training, implement secure gateways.		
Risk Monitoring and Review			
Risk Owner	CISO		

To	CIO,CISO, IT Security Manager, IT Risk Manager
Cc	SOC Team
Bcc	
Subject	High Risk of Phishing or Social Engineering Attack Resulting in Credential Compromise

Risk Details			
Risk ID	R2	**Date Identified**	3/31/2026
Risk Title	BYOD Data Leakage	**Review Date**	3/31/2026
Risk Identification			
Risk Description	Employees using personal devices to access proprietary systems can result in sensitive data being leaked if the personal device is compromise.		
Assets at Risk	Customer Data, VPN and Remote Access to Internal Servers, Internal Communication Systems.		
Threat	Attacker infecting devices with malware, stealing devices, or unauthorized access.		
Vulnerability	Lack of MDM and robust security controls on personal devices.		
Existing Controls	RBAC, VPN, firewalls.		
Inherent Risk Analysis			
Likelihood	**Consequence**	**Inherent Risk Rating**	
3	3	Medium	
Residual Risk Analysis			
Likelihood	**Consequence**	**Residual Risk Rating**	
1	2	Low	
Risk Treatment			
Mitigations	Implement strong MDM system, enforcement of password and screen locking, separation of personal and proprietary data.		
Risk Monitoring and Review			
Risk Owner	IT Operations Manager		

To	CIO, IT Security Manager, IT Operations Manager
Cc	
Bcc	
Subject	High Risk of Data Leakage from BYOD Policy

Risk Details			
Risk ID	R3	**Date Identified**	3/31/2026
Risk Title	Third-Party Vendor Breach	**Review Date**	3/31/2026
Risk Identification			
Risk Description	A third-party vendor breach would result in damage to reputation, supply chain functionality, and loss of customer data.		
Assets at Risk	Customer Data, Production, Customer Relationships		
Threat	Attacker compromises a third-party vendor		
Vulnerability	Lack of auditing and risk assessments of vendors.		
Existing Controls	N/A		
Inherent Risk Analysis			
Likelihood	**Consequence**	**Inherent Risk Rating**	
5	4	Extreme	
Residual Risk Analysis			
Likelihood	**Consequence**	**Residual Risk Rating**	
3	4	High	
Risk Treatment			

Mitigations	Implement right-to-audit clause within all vendor contracts, conduct regular risk assessments on vendors, limit access to internal systems by vendors.
Risk Monitoring and Review	
Risk Owner	Vendor Risk Manager

To	CISO, Vendor Risk Manager, Compliance Manager
Cc	
Bcc	
Subject	High Risk Involving Third-Party Vendors Could Result in Substantial Loss

Cybersecurity Risk Prioritization Matrix

Understanding the Likelihood Rating

The table below provides the categories and ratings for likelihood:

Likelihood Ratings	Description	Criteria
Rare (1)	Exceptional circumstances only	May occur only in very unusual situations
Unlikely (2)	Possible, but not expected	Could happen but not typical; requires specific conditions (e.g. targeted phishing bypassing all filters).
Possible (3)	Might occur at some point	Has occurred in similar organisations; realistic but not frequent (e.g. ransomware attempt on enterprise endpoint).
Likely (4)	Will probably occur in most circumstances	Expected to happen periodically (e.g. phishing emails, credential stuffing attempts).
Almost Certain (5)	Expected to occur frequently	Has occurred multiple times, highly predictable (e.g. malware probes, daily scanning activity).

Understanding the Consequence Ratings Table

The table below provides the categories and ratings for impacts:

Consequence Rating	Description	Criteria
Insignificant (1)	Negligible impact	No compromise of sensitive data, no disruption, minimal financial or reputational impact.
Minor (2)	Small impact	Limited operational disruption; minimal data exposure (non-sensitive data); easily contained.
Moderate (3)	Noticeable impact	Partial service disruption; limited sensitive data exposure; moderate cost or compliance breach.
Major (4)	Severe impact	Significant outage of critical systems; large-scale sensitive data breach; regulatory non-compliance with penalties.
Extreme (5)	Catastrophic impact	Extended enterprise-wide outage; compromise of PROTECTED/SECRET data; severe financial/reputational damage; possible criminal or regulatory prosecution.

The 5x5 Risk Matrix

Use this 5x5 risk matrix to evaluate and prioritize cybersecurity risks. For each identified risk, assess its likelihood (1 = Rare, 5 = Almost Certain) and impact (1 = Insignificant, 5 = Critical). Plot the risk in the matrix and use the result to guide mitigation priorities.

Likelihood ↓ Impact →	Insignificant (1)	Minor (2)	Moderate (3)	Major (4)	Extreme (5)
5 – Almost Certain	**MEDIUM**	**HIGH**	**HIGH**	**EXTREME**	**EXTREME**
4 – Likely	**MEDIUM**	**MEDIUM**	**HIGH**	**HIGH**	**EXTREME**
3 – Possible	**LOW**	**MEDIUM**	**MEDIUM**	**HIGH**	**HIGH**
2 – Unlikely	**LOW**	**LOW**	**MEDIUM**	**MEDIUM**	**HIGH**
1 – Rare	**LOW**	**LOW**	**LOW**	**MEDIUM**	**MEDIUM**

Risk Levels

- **Low** – Acceptable; manage by routine controls and monitoring.
- **Medium** – Requires management attention; additional controls may be needed.
- **High** – Significant; must be treated with priority, monitored closely, and escalated to senior management.
- **Extreme** – Unacceptable; immediate executive-level attention and remediation required.

Tips for Completing the Matrix

- Start by identifying the risk scenario (e.g., data breach, system outage).
- Assign a likelihood score based on how often this type of risk occurs.
- Assign an impact score based on potential damage to operations, reputation, or finances.
- Use the matrix to prioritise: risks in the top-right corner (high likelihood and impact) need urgent attention.

Risks in Prioritization Order and Explanations:

1. **R3 - Third-Party Vendor Risk (Extreme):** The likelihood of this risk is rated at a 5, meaning it is almost certain to happen. This has already happened in 2025, when a compromised vendor leaked 5,000 customers' email addresses. The impact of this risk is 4, meaning the result of this risk would have severe regulatory and reputational consequences. The mitigation efforts for this risk should involve regular audits and risk assessments of vendors, as well as a limit to how much proprietary and customer data they have access to.
2. **R1 - Phishing Attack Compromising Credentials (High):** The likelihood of this risk is rated at a 4, meaning it is likely to occur. This type of attack has already occurred in 2023, where employees were targeted and credentials were compromised. The impact of this risk is 4, meaning the result would have severe consequences, including unauthorized access to internal systems and potential exposure of customer data. The mitigation efforts for this risk should involve enforcing multi-factor authentication, implementing advanced email filtering systems, and conducting robust and regular security and phishing awareness training for employees.
3. **R2 - BYOD Data Breach (Medium):** The likelihood of this risk is rated at a 3, meaning it is possible to occur. While there have been no reported incidents, the use of personal devices increases the attack surface and introduces risk through lost, stolen, or compromised devices. The impact of this risk is 3, meaning the result would have moderate consequences, such as unauthorized access to internal systems or limited exposure of sensitive data. The mitigation efforts for this risk should involve implementing mobile device management system, enforcing device encryption and security policies, and separating personal and proprietary data.